II – Sécurité : Cryptologie

© PSO - 2023

La sécurité

La mise en place d'un véritable stratégie de sécurité réseau est indispensable pour la sécurisation des données informatiques de votre entreprise. A ce titre, il faut comprendre quelles peuvent être les menaces, les règles à mettre en place et les technologies de sécurité associées, telles que **l'encryptage**, **l'authentification** et les **firewalls**.

DECIT

© PSO - 2023

Introduction

On distingue 5 types de besoins de sécurité:

1. **la continuité du service**: il s 'agit de maintenir le canal de transmission en fonctionnement, éventuellement en mode dégradé.
2. **la confidentialité des informations**, pour qu'elles ne tombent pas aux mains d 'un tiers non-autorisé
3. **l 'intégrité**, c 'est-à-dire la certitude que l 'information n 'a pas été altérée pendant son transport
4. **l 'authentification**, pour être sûr qu'émetteur et destinataire sont bien les personnes qu'elles prétendent être.
5. **La non répudiation des données** (on ne peut nier d'avoir envoyé le message).

DECFT

© PSO - 2023

Menace : Interception

- Confidentialité : l'intercepteur ne peut lire les données.
- Intégrité : les données ne peuvent être modifiées sans que cela ne soit détecté.

Pour répondre à ces deux problématiques l'on retrouvera deux technologies qui sont :

a) **L'encryptage** (codage) des données.

b) Les fonctions de **hachage**.

© PSO - 2023

Menace : L'imposture

- L'imposteur prétend être une personne autorisée.
- Réponse : **L'authentification** afin de s'assurer que la personne ou l'entreprise qui communique avec nous est bien celle qu'elle prétend être.

  Pour répondre à cette problématique l'on retrouvera 2 technologies qui sont :

a) La **signature électronique**.

b) Les **certificats**.

© PSO - 2023

Menace : Le déni de service

- Surcharge du système par une inondation de message.
- Envoi d'un message qui paralyse la machine en utilisant une faille qui va bloquer le système.

a) Afin de contrer la première menace, la politique de sécurité est de mettre en place une **stratégie de détection de menace de déni de service** et refuser ensuite la connexion des machines mal intentionnées.

b) Pour la seconde qui s'attaque aux failles potentielles d'un système, l'administrateur du système devra s'assurer que les derniers **niveaux de correctif sont toujours mis en place.**

© PSO - 2023

Menace : Les applications

- Virus.
- Accès à une application non protégée qui ouvre votre système et permet ainsi à des pirates de se servir de votre système pour parvenir à leur fin (par exemple se connecter à d'autres serveurs, ou effectuer des opérations illicites, etc.) (Zombie)

Afin de contrer la première menace, la politique de sécurité est de mettre en place une **stratégie de détection de ces programmes** et de mettre en place des moyens pour les éradiquer (**firewall, anti-virus, anti-spams, etc.)..**

© PSO - 2023

La politique de sécurité

Accès	Sécurité
Connectivité	Fiabilité
Performance	Confidentialité
Transparence	Intégrité

La politique de sécurité doit être une balance entre ***être sécurisé sans que les utilisateurs finaux ne soient pas trop pénalisés****. Il ne faut pas compromettre les performances, connectivité et transparence par une sécurité trop forte et inversement.*

© PSO - 2023

Le chiffrement et ses usages

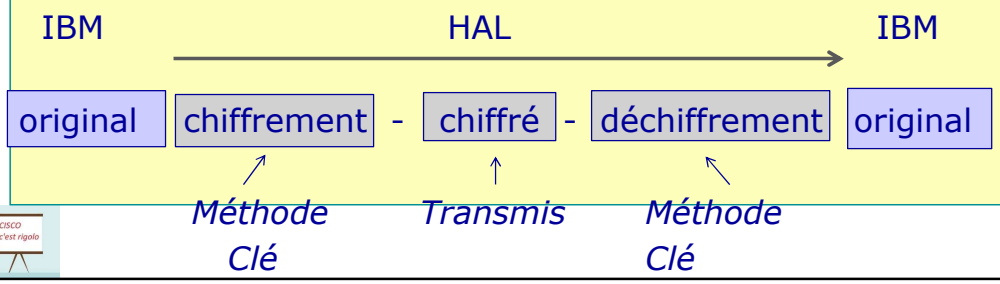
- **Cryptographie**: conception des méthodes de chiffrement
  - Chiffrer/déchiffrer: activités de codage et décodage associées
- **Cryptologie**: résoudre des problème de sécurité associé à la communication en réseau

  Les 2 principaux problème sont :
  - L'échange confidentiel d'informations
  - Authentification des participants

© PSO - 2023

Techniques de base de la cryptologie

- Les algorithmes de chiffrement ont pour rôle de **rendre incompréhensible un message** pour toute personne autre que son destinataire.
- Les algorithme de chiffrement sont de 2 types :
  - Symétrique à clé secrète
  - Asymétrique à clé publique
- Principe général du chiffrement:



© PSO - 2023

Algorithme et clés

- Le chiffrement (et le déchiffrement) c 'est l 'application d 'une fonction mathématique (un algorithme) au message paramétrée par la clé
- **L 'algorithme de chiffrement lui-même n 'est pas secret** , Toute la sécurité repose sur le maintien secret de la clé qui constitue l'élément variable dans le processus de chiffrement
- **La clé**, par contre, doit être changée le plus souvent possible et **bien sûr être gardée secrète**

- Les clés de chiffrement peuvent être **identiques** (algo à clés secrètes) ou **différentes** (algo à clés publiques) . La complexité de décryptage d 'un message varie la longueur de la clé

© PSO - 2023

Exemple d'une clé

- Une clé est simplement un fichier comportant une suite de bits. Voici un exemple de clé :


```
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: DES-EDE3-CBC,F23A96255F3F177A

R7GcxbfXoBEprasrQY1kVk9a+LN+8roRVZjq0EJoY3t8dYHnv6yVQfi/lvLKuA0/
5yoCN/kTv0KlqpHmv/8jIBuQSCCV9cRyt9VPypEBDot52mHseubA3oWbxF3M+Nat
IP5Es11Xu6n9HtCnXf82fYAAsjAZHk5cRmYA1lOs8lekrk3jY1JpOxMzWYGPtwQw
46akos1WUeFMh6ngKehDdbRtykGcQoE+5XB1KU2btV6QaOpWLcskM8X65bIDvMvI
LIw1yjLNNkigKkV96vqWWkAWuUmiRjyAHqejAsdTMzzQ/G8dD7HuVhlpSrp8PyAA
xp8/u6Vja9BulW9k51gmlgqqlaybwjhPzKkLmwJw7yXGGrTzequHeld/FaCnOcsL
gQlnUszVl4xZb1r70vml6Exh3s/uujyqAtfywypelv7/j5bMCEY9kK+CjEHFUBub
ds+PQtfriYKsFK6igQwPixFuNT5xgRfb6vT6XWjzPYuWatyNfKLlIkGPyj9KMTHa
t/UF+m8i+bXwIPrYWre/eOCqev2GQ+kQ7vViY/3ZnnfRI211cxdUrqBAmK0aedPk
F+Cf7SmcmxmFsg6BoGeKYlxgVLIMmVcjTimq2JCLgeeQecYqmYbujd2ODjlhNDGS
v3VWEx7wFYGktl+V97+7tX29FQ6Ca0CSA4XzDkgVbXCbU1vys8zqeM2id/5SIZfl
I4nAJiCRRy7OhF1Iy/37xp59V6qjyvp/R4+ruOtdpZ2J8makyCE2+HiZMbotXo/5
cQCVK5Zz3VYIOtutU6qC2Dhg4UGHE2cBtYKMBcSNKBDl3JdIzE1UTg==
-----END RSA PRIVATE KEY-----
```


© PSO - 2023

Chiffrement par substitution

- Dans la méthode par substitution, **chaque lettre** (ou chaque groupe de lettres) **est remplacée par une autre lettre** (ou un autre groupe de lettres)
- La plus ancienne est le Jules César: a devient d, b devient e, c devient f, etc…

  exemple: attaque devient dwwdtxh
- Amélioration: au lieu de décaler de 3 lettres (ou même de n lettres) on substitue chaque lettre par une lettre quelconque la clé est donc de 26 lettres et il y a donc 26! = 4.10^{26} combinaisons possibles
- ce pendant il est facile de casser ce code en cherchant la fréquence d'apparition des lettres (e la plus fréquente, etc…) ou de groupes de 2 lettres (ch, qu, etc…) ou de 3 lettres (ion, eau, etc…)

© PSO - 2023

Chiffrement de Jules César

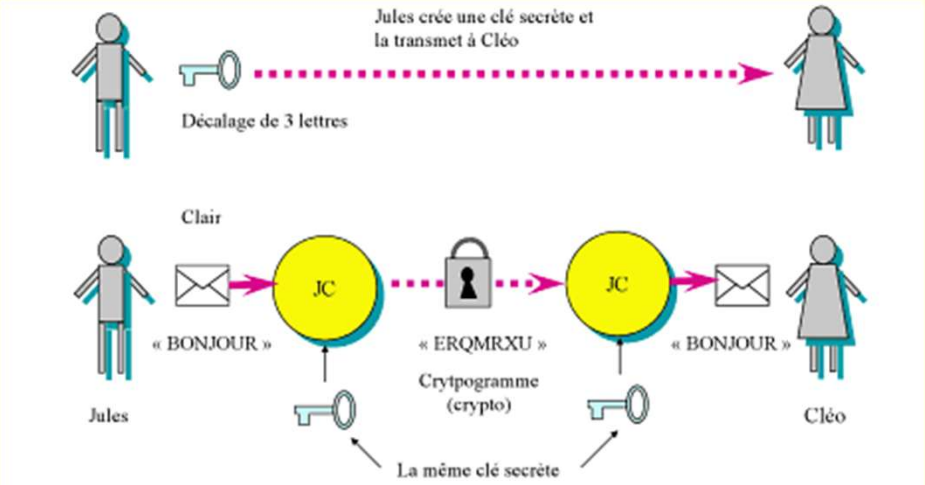


Fig. Le chiffrement de Jules César

© PSO - 2023

Chiffrement par transposition

- Dans ces méthodes c 'est l 'ordre des lettres qui est modifié (les lettres elles-mêmes n 'étant pas modifiées)
- **Principe:**

1. on se donne une clé
2. on range en lignes le texte en clair
3. on lit en colonnes dans l'ordre alphabétique

des lettres de la clé pour obtenir le texte chiffré

- **Exemple**: clé: BIDULE (142653)

Texte en clair:

ACHETER_DEUX_MILLE_ACTIONS_DE_LA_SOCIETE_PEUGEOT

Texte chiffré:

AR__NLIEHDIC__TGEXEO_CPTC_MASAEUTULIEO_OEELTDSEE

14 2 6 53
BIDULE
ACHETE
R_DEUX
_MILLE
_ACTIO
NS_DE_
LA_SOC
IETE_P
EUGEOT

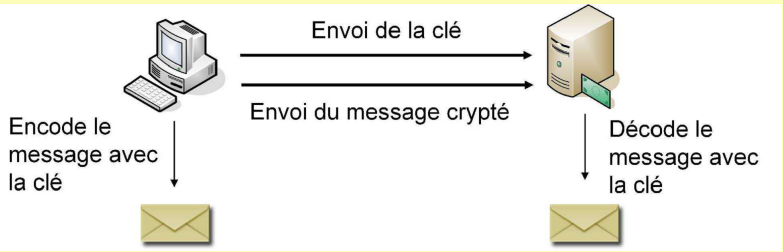
© PSO - 2023

Algorithmes à clé symétrique

© PSO - 2023

Cryptage Symétrique

- Le cryptage symétrique aussi appeler cryptage à clé secrète, utilise une **même clé** de cryptage afin de crypter et de décrypter un document. Cette clé doit donc être connue des deux parties.



© PSO - 2023

Méthodes à clé secrète

- La même clé est utilisée des deux côtés pour le chiffrement et le déchiffrement.
- **La clé unique doit être secrète.**
  - Toute personne connaissant la clé peut lire le message.
- La protection est proportionnelle à la longueur de la clé.
  - n bits peuvent être découverts en 2^n essais.
  - Sécurité : faible 40 bits, forte 128 bits.

© PSO - 2023

Cryptage Symétrique

- **Le cryptage symétrique est utilisé dans la plus part des protocoles de cryptages (SSL,IPSec…)**

Avantage : plus simple et plus rapide que le cryptage asymétrique

Limitation : est la façon dont est échangé la clé. Si une personne se procure la clé, elle pourra décrypter tous les messages. Aussi pour contrer cela on utilisera un cryptage Asymétrique pour l'échange de la clé secrète.

Quelques Algorithme de cryptage Symétrique :

a) DES (Data Encryption Standard)
b) 3DES
c) RC-4 (River Cipher – 4)
d) AES (Advanced Encryption Standard)

© PSO - 2023

Modes de chiffrement

- Les méthodes à clés privées se divisent en deux types :

1. Chiffrement par **flot :** les données sont traité en flux . (*Pas besoin de lire le message, ni d'avoir sa longueur pour commencer a chiffrer.)*
   - Traitement bit par bit
   - (RC4 ou Arcfour)
2. Chiffrement par **blocs :** Les messages sont découpés en blocs
   - (AES,3DES,Blowfish,IDEA…)

© PSO - 2023

Xor et Chiffrement

Voici un exemple :

M = 0110101011010100 (message en clair)

K = 0101011011100110 (la clé à garder secrète)

- Le symbole $\oplus$ représente ici l'application de l'opérateur XOR à chacun des bits :
- Chiffrement : $C = M \oplus K$ = 0011110000110010 (message chiffré)
- Déchiffrement : $M = C \oplus K$ = 0110101011010100 (message déchiffré)

© PSO - 2023

Codage par blocs

- Le chiffrement par bloc qui reçoit **un bloc de texte en clair de *n bits* en restitue un bloc de *n bits* de texte chiffré avec la clé**
- Le message clair est divisé en blocs uniforme de bits (exemple 128 bits pour AES), et un algorithme chiffre un bloc à la fois.
- La taille de ces blocs est primordiale pour la sécurité de la communication ; par contre, les grands blocs sont plus sécuritaires mais aussi plus lourds à transférer.

© PSO - 2023

La taille des clés

- Les algorithmes à **clés secrètes** utilisent des clés plus ou moins longue.
- Un pirates dispose d'une méthode simple pour trouver le message clair : c'est d'essayer toutes les clés possible.
- Cette méthode, appelée « l'attaque exhaustive » est d'autant plus efficace que les clés sont courtes.
- On exprime la taille de la clé (et donc le nombre de clé possibles) en puissance de 2.
- Exemple : **une clé de 40 bits signifie qu'il existe 2^{40} clés possibles.**

© PSO - 2023

Taille des clés

- Les experts considèrent qu'un algorithme à clé secrète doit utiliser des clés de plus de 100 bit pour assurer une sécurité parfaite.

Système de chiffrement	Taille des clés
AES	128, 192 OU 256 BITS
Camelia	128, 192 OU 256 BITS
3DES	112 bits
DES	56 bits
RC4	40 à 256 bits
Blowfish	32 à 448 bits
CAST5	128 bits
IDEA	128 bits

© PSO - 2023

Un bon système de chiffrement symétrique ?

- **Il doit résister à une attaque exhaustive** (clé utilisé doit être au moins de 128 bits)
- **Il ne doit pas contenir de faille théorique** qui permettrait de décrypter les messages sans explorer toutes les clés. Seuls des mathématiciens peuvent réaliser ce type d'attaque. Ainsi il ne faut utiliser que les méthodes connue (AES,3DES…)
- **Il doit être rapide**
- **Il doit être simple** (pour un mathématicien). Il sera plus facile de détecter une faille théorique.

© PSO - 2023

Le problème de la distribution

- Lorsque une personne échange sa clé secrète avec une autre, il existe un risque potentiel d'interception du message et donc de lecture de la clé. Aussi, le chiffrement symétrique impose d'avoir un canal sécurisé pour l'échange de la clé, ce qui dégrade sérieusement l'intérêt d'un tel système de chiffrement.
- De plus pour **chaque partenaire différent, on doit avoir une clé secrète différente**; Il est hors de question de partager les mêmes clés.
- Cela nous amène au principal inconvénient du chiffrement à clefs secrètes : **la distribution des clés**.

© PSO - 2023

Algorithmes à clé publique

Cryptage Asymétrique

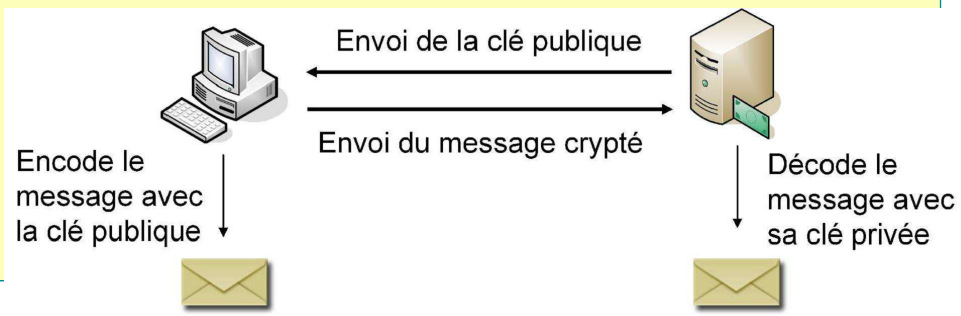
Des clés différentes sont utilisées pour le chiffrement et le déchiffrement : D(E(M)) = M

Algo de chiffrement **E**, Algo de déchiffrement **D**, **M** message en clair

Méthode à clés Publiques

– *Chiffrement par **la clé publique** du récepteur.*

– *Déchiffrrement par la **clé privée** du récepteur.*



Cryptage Asymétrique

Quelques algorithmes de cryptographie asymétrique très utilisés:

- **RSA** (initiales de Rivest, Shamir et Adelman, les inventeurs) a été créé en 1978 au MIT (chiffrement et signature);

- ***DSA*** (Digital Signature Algorithm) développée par Claus-Peter Schnorr en 1989 (chiffrement)

© PSO - 2023

La méthode RSA

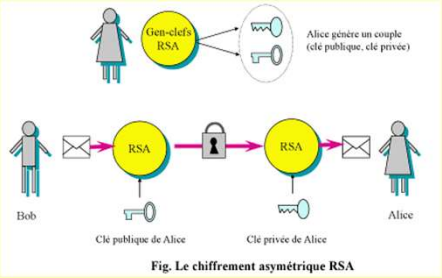


Fig. Le chiffrement asymétrique RSA

© PSO - 2023

RSA

Calcul des clés:

- on prend 2 nombres premiers, **p** et **q** plus grands que 10^{100} (en général de 1024 bits)
- on calcule **n=p.q** et **z=(p-1).(q-1)**
- on choisit un nombre **d** premier avec **z** (c'est-à-dire pas de facteur commun entre **d** et **z**)
- on cherche **e** tel que **e.d** =1 (mod **z**) ou **e.d** (mod **z**) = 1

© PSO - 2023

RSA

- **Chiffrement d 'un message:**
  - on regroupe le texte clair **M** en blocs de **k** bits tels que **2k<n**, chaque bloc constituant un nombre **M** compris entre **0 et n**
  - on chiffre chaque bloc **M** en calculant **$C=M^e$ (mod n)**
- **Déchiffrement:**
  - le déchiffrement s 'obtient en calculant **$M=C^d$ (mod n)**
  - **La clé publique est le couple (e,n) et la clé privée (d,n)**
- RSA est trop lent. Il est très utilisé pour distribuer les clés DES!

© PSO - 2023

exemple

- **p =3** et **q=11**
- **n**= p*q = 3*11 = **33**
- **z**=(p-1).(q-1) = 2 * 10 = **20**
- On prend **d = 7** (pas de facteur commun entre 7 et 20)
- **e.d** (mod **z**) = 1 = 7*e(mod 20) = 1
- Donc **e=3**
- on chiffre chaque bloc **M** en calculant **$C=M^e$ (mod n) = M^3(mod 33)**
- On déchiffre en calculant **$M=C^d$ (mod n) = C^7 (mod 33)**
- **La clé publique est le couple (e,n) = (3, 33)**
- **La clé privée (d,n) = (7,33)**

© PSO - 2023

Texte en clair M			Texte chiffré C	Aprés déchiffrement		
Symbo	Numéric	M^3	M^3(mod 33)	C^7	C^7(mod33)	Symbo
S	19	6859	28	13492928512	19	S
U	21	9261	21	1801088541	21	U
Z	26	17576	20	1280000000	26	Z
A	01	1	1	1	01	A
N	14	2744	5	78125	14	N
N	14	2744	5	78125	14	N
E	05	125	26	8031810176	05	E

Calculs fait par l'expéditeur

Calculs fait par le destinataire

© PSO - 2023

Avantages des méthodes à clés publiques

- La cryptographie à clé publique offre plusieurs avantages :

1. **Elle diminue le nombre de clés nécessaire à la communication** entre un nombre important de personnes. (En clé secrète si 4 personnes veulent communiquer ensemble il faut 6 clés, 4 seulement avec RSA)
2. **Elle permet la signature** d'un document numérique
3. **Elle permet l'authentification mutuelle** de deux correspondants.

© PSO - 2023

Symétrique ou asymétrique ?

- **Symétrique**

– Calcul rapide, distribution complexe.

- **Asymétrique**

– Calculs complexes, distribution simple.

Enormément d'application **utilisent conjointement le cryptage symétrique et le cryptage asymétrique**.
Les données sont cryptées à l'aide d'un (ou plusieurs) clé secrète (cryptage symétrique), l'échange de ces clés secrètes s'effectuant par un cryptage asymétrique. Le cryptage symétrique est donc utilisé pour crypter les données, ce qui accélère le processus de cryptage et de décryptage. **SSL utilisent ce procédé**

© PSO - 2023

Clé de sessions

- Du fait de la lenteur des algorithmes à clés publiques, ils ne sont utilisés que pour chiffrer des messages très cours, par exemple des clés secrètes, appelées alors **clés de sessions**, utilisées par les algorithmes symétriques.

© PSO - 2023

L'authentification

- Prouver l'identité de l'émetteur.

  Méthodes :
  - Mot de passe: faible.
  - Biométrie (emprunte digitale, analyse de l'iris) : contraignant.
  - Clé publique : L'émetteur prouve qu'il détient sa clé privée. Seule la clé publique permet le décodage
- Permet la non répudiation
  - L'émetteur ne peut nier avoir émis le message.

© PSO - 2023

Signature numérique

© PSO - 2023

Signatures numériques

- On a besoin d'un système dans lequel une des parties peut envoyer un message signé à l'autre partie en remplissant les conditions suivantes :

1. Le destinataire peut vérifier l'identité dont se réclame l'expéditeur.
2. L'expéditeur ne peut pas répudier plus tard le contenu du message
3. Il est impossible pour le destinataire de fabriquer lui-même un tel message.

© PSO - 2023

Signature par clé publique

- ALICE signe le message avec SA clé privée.
- Le message est transmis
- BOB authentifie le message avec La Clé publique de ALICE

La clé privée n'est jamais transmise
Le message transite non chiffré

© PSO - 2023

L'authentification mutuelle

- ALICE veut envoyer un message à BOB, mais il désire que le message reste secret et que seule BOB puisse le lire et soit sur qu'il provient de ALICE.

1. ALICE chiffre son message avec sa clé privé
2. ALICE sur-chiffre le résultat avec la clé publique de BOB.
3. ALICE transmet le message à BOB
4. BOB utilise sa clé privé pour déchiffrer le message
5. BOB utilise ensuite la clé publique de ALICE pour déchiffrer le résultat précédent.

© PSO - 2023

Signature et non répudation

- La signature numérique est utilisée afin de **garantir l'identité de l'émetteur** ainsi que **l'intégrité des données** (pour en prévenir toute falsification). La signature numérique peut être utilisée conjointement ou non avec le cryptage.
- Elle met en œuvre l'utilisation d'une fonction **de hachage non réversible** ainsi que l'utilisation du cryptage asymétrique afin de garantir l'identité de l'émetteur.

© PSO - 2023

Condensats de message

- Une fonction de hachage (hash) est capable de traiter un texte en clair de longueur libre et à partir de celui-ci de calculer une chaine de bits de longueur fixe. Cette fonction de hachage ,*MD* souvent appelée **Condensat de message** (Message Digest) , à 4 propriétés :

1. Pour tout M, il est facile de calculer MD(M)
2. Quel que soit MD(M), il est impossible de retrouver M
3. A partir de M, personne ne peut trouver un M' tel que MD(M') = MD(M)
4. Une modification d'un seul bit dans le texte traité produit un résultat très différent.

- Le calcul d'un **condensat de message** est plus rapide que le chiffrement du texte avec un algo à clé publique. Donc cela accélère le traitement des algo signature

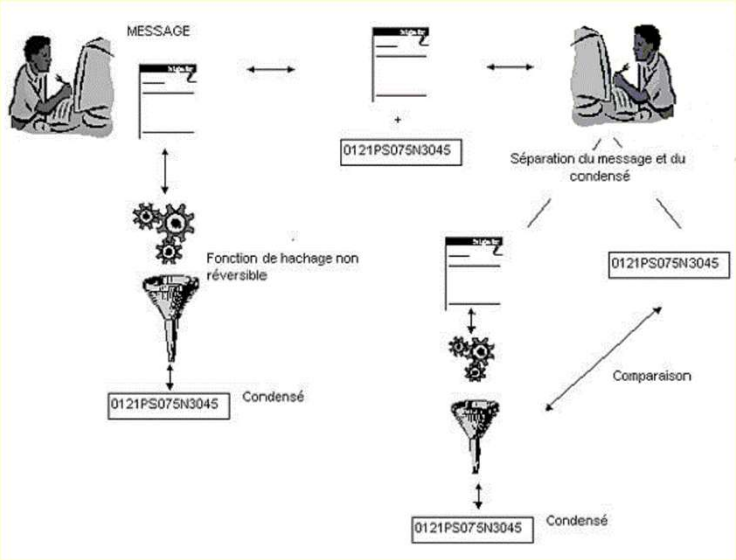
© PSO - 2023

Fonction de Hachage

- Les fonctions de hachage (ou générateurs d'empreintes ou hash function) ont un rôle similaire à celui de CRC. Elles permettent de créer l'empreinte numérique d'un message.
- Cette empreinte dépend mathématiquement du message.
- Si on modifie un tant soit peu le message, l'empreinte associée est complètement différente. Par conséquent les fonctions de hachage **vérifient qu'un message (ou fichier) n'a pas été altéré.**
- **MD5 et SHA** sont Les 2 principaux algorithme de hachage**.**

© PSO - 2023

Hachage



© PSO - 2023

Hachage

1. Un utilisateur rédige un message et le soumet à un algorithme de hachage non réversible (md5 ou sha)
2. Le résultat de la fonction de hachage est joint au message original sous forme d'empreinte numérique (appelée **Condensé**)
3. Le message et le condensé est envoyés au destinataire
4. Le destinataire sépare le condensé du message original, et soumet le message à la même fonction de hachage non réversible que celle utilisé par l'émetteur.
5. Le destinataire compare le résultat obtenu au condensé envoyé par l'émetteur. **Si le résultat est identique, alors le message n'a pas été modifié lors de la transmission**.

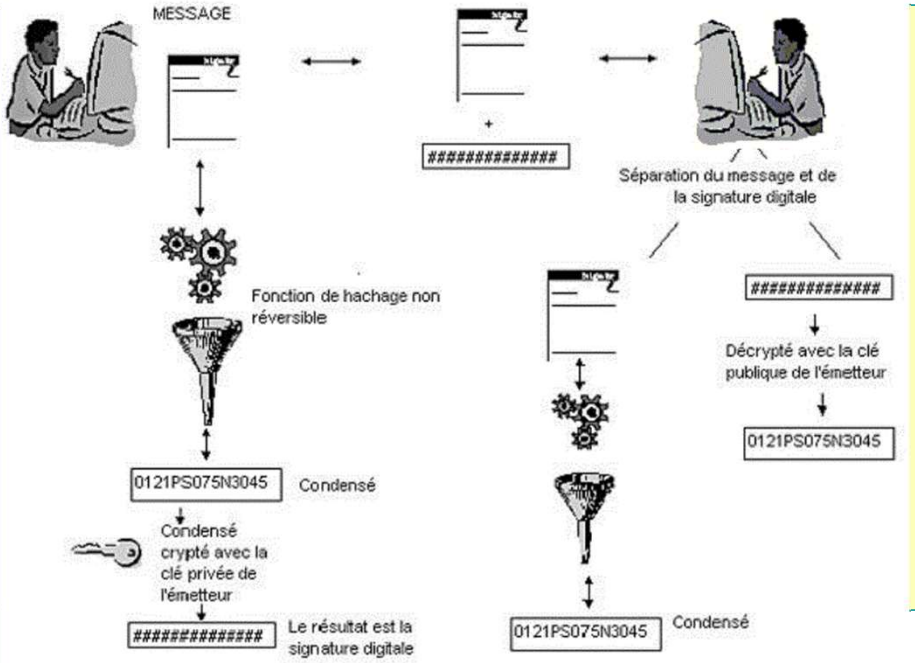
© PSO - 2023

Fonction de Hachage

- Un même message en entrée doit toujours reproduire le même résultat (**condensé**)
- Le condensé doit être **unique** (2 messages différents en entrée ne peuvent pas donner le même résultat après être passés dans la fonction de hachage.
- Un algo de hachage doit être **non réversible**, c'est-à-dire qu'il est quasiment impossible de retrouver le message original à partir du condensé.
- Les principaux algorithme de hachage actuellement utilisés sont **MD5** (Message Digest 5) et **SHA** (Secure Hash Algorithm).
- SHA et plus puissant que MD5 mais plus consommateur de ressource.

© PSO - 2023

Signature



© PSO - 2023

Signature (1/2)

1. L'émetteur possède une paire de clés publique /privée et envoie sa clé publique au destinataire.
2. Il soumet son message à une fonction de hachage non réversible.
3. Il utilise ensuite sa clé privée afin de signer le condensé. Le résultat est donc la signature numérique.
4. Le message ainsi que la signature numérique sont envoyés au destinataire

© PSO - 2023

Signature (2/2)

5. Lorsque le destinataire reçoit le message, il sépare le condensé du message, il utilise la clé publique de l'émetteur afin de décrypter le condensé et obtient donc le condensé de l'étape 2.
6. Le destinataire soumet ensuite le message à la même fonction de hachage que celle utilisée par l'émetteur.
7. Le destinataire compare les 2 condensés ainsi obtenus. Si les résultats sont identiques alors le destinataire est sûr que l'émetteur est bien à l'origine du message et que le message n'a pas été modifié lors du transfert

© PSO - 2023

Signature

- La signature numérique seule apporte uniquement **une sécurité sur l'émetteur du message** ainsi que son **intégrité**. Par contre le message est envoyé en **clair sur le réseau**. Il faut donc pour assurer la confidentialité du message, il faut en plus utiliser un cryptage du message.

- Le cryptage asymétrique, par la signature numérique ajoute la notion **de non-répudiation** d'un message. C'est-à-dire la personne ayant émis un message ne peut nier l'avoir envoyé (car il a utilisé sa clé privé pour signer le message)

© PSO - 2023

L'attaque de l'homme du milieu

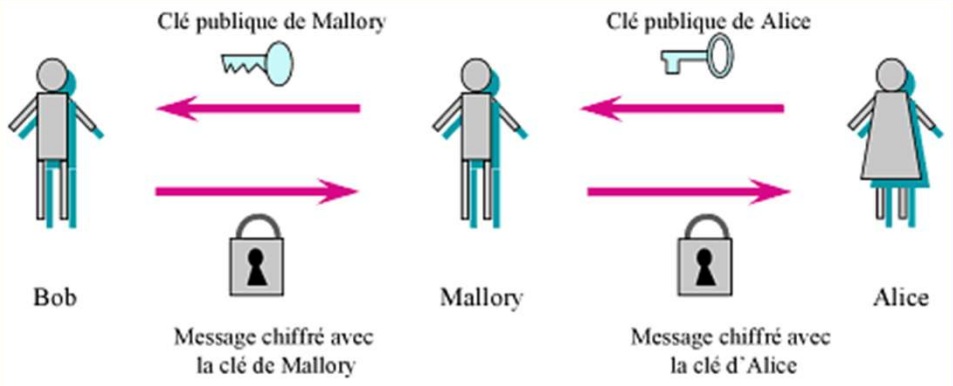


Fig. L'attaque de l'homme du milieu

© PSO - 2023

L'attaque de l'homme du milieu

- ALICE envoie à BOB sa clé publique, MALLORY intercepte cette clé et envoie à BOB sa propre clé publique.
- BOB envoie un message à ALICE , chiffré avec la clé de MALLORY. MALLORY intercepte le message, le déchiffre avec sa clé privée. Elle le rechiffre avec la clé publique d'ALICE et l'envoie à ALICE.
- Le problème nait du fait BOB accepte la clé de MALLORY comme étant celle de ALICE.
- En fait a question est : **comment établir la confiance avec un inconnue ?**. Par contre si un tiers de confiance nous présent un inconnu on pourra établir la confiance.
- L'utilisation de **certificats x509 est une solution** à ce problème, car il joue le rôle du tiers de confiance

© PSO - 2023

Les Certificats

© PSO - 2023

Les Certificats

- **Un certificat de clé publique, est un document électronique signé numériquement qui lie la valeur d'une clé publique à l'identité de la personne, de la machine, ou service qui contient la clé privé correspondante**
- Les certificats sont créés et gérés par une organisation indépendante appelée **autorité de certification (CA)**. Lorsque un utilisateur ou une entreprise en fait la demande, l'autorité de certification délivre les certificats et leur assigne **une date de validité** (équivalent à la date limite de péremption des produits alimentaires). Elle peut aussi révoquer éventuellement des certificats avant cette date en cas de compromission de la clé (ou du propriétaire).

© PSO - 2023

Le certificat numérique.

- Un tiers agréé vous fournit un certificat numérique qui permet ensuite de prouver son identité. **Ce certificat est ensuite associé à tous messages envoyés**.
- **Un certificat va permettre d'associer une clé publique à une entité** (une personne, une machine, ...) afin d'en assurer la validité. Le certificat est en quelque sorte la carte d'identité de la clé publique, délivré par un organisme appelé **autorité de certification**.

© PSO - 2023

- En fait, par le principe de la signature d'un tiers, on reporte le problème de la confiance sur ce tiers. ou émetteurs de certificats (Certificate Authority, CA en anglais).
- Ce sont des organismes privés, comme ceux donnés en exemple, ci-dessous qui vont se charger (moyennant finances) d'apporter leur signature électronique aux certificats.
  - Verisign http://www.verisign.com
  - Thawte http://www.thawte.com
- Ces organismes publient des annuaires de certificats signés par leur soin.

© PSO - 2023

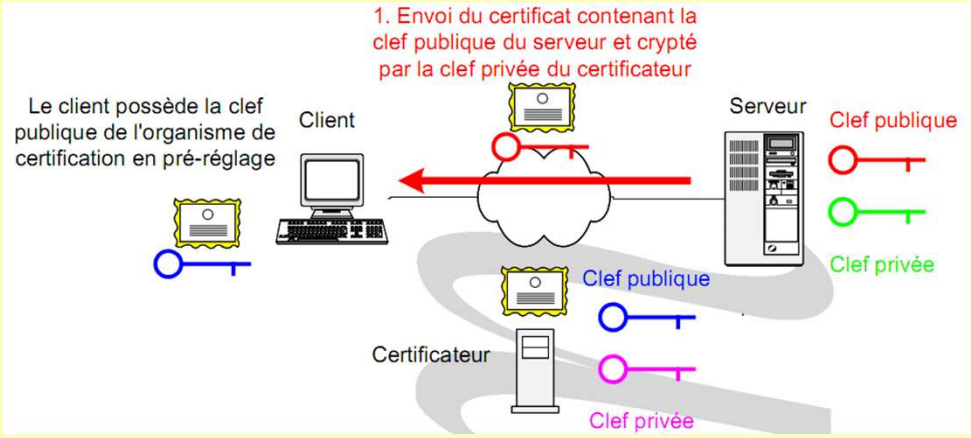
Les certificats

- Un certificat peut se définir comme une affirmation numérique, émise par **une autorité, et garantissant l'identité du détenteur du certificat.**
- Le format standard des certificats est le **X.509 v3.**

Un certificat contient les informations suivantes :

- La **clé publique du sujet**
- Des informations identifiant le sujet (son nom, email…)
- La **période de validité**
- Des informations identifiant l'autorité de certifications
- **La signature numérique de l'autorité** de certification qui atteste de la validité de la liaison entre la clé publique du sujet et les informations d'identification de ce dernier

© PSO - 2023



© PSO - 2023

Certificat X509, signature par le CA

- Bernard Dupont
- bdupont@greta.com
- GRETA, RUEIL MALMAISON, IDF, FR
- CA-Greta
- ca-greta@greta.com
- GRETA, FR
- Validité : 09/08/2012-08/07/2014
- Kpub de Dupont : 01:00:B3:09:……

Hachage

Empreinte

Clé Privée de CA-GRETA

Chiffrement

Empreinte chiffrée par Kpriv de CA-Greta
B2:C1:1C:F1:8F:7B:51:…..

Certificat X509, signature par l'autorité de certification. Dans cet exemple le Greta est l'autorité de certification

© PSO - 2023

Certificat X509, vérification

- Bernard Dupont
- bdupont@greta.com
- GRETA, RUEIL MALMAISON, IDF, FR
- CA-Greta
- ca-greta@greta.com
- GRETA, FR
- Validité : 09/08/2012-08/07/2014
- Kpub de Dupont : 01:00:B3:09:……

Hachage → *Empreinte calculée*

Comparaison = ?

Empreinte chiffrée par Kpriv de CA-Greta
B2:C1:1C:F1:8F:7B:51:…..

Déchiffrement → *Empreinte déchiffré*

Clé Publique de CA-GRETA

Vérification de la validité du certificat

© PSO - 2023

Format d'un certificat X509

- Version
- Numéro de série
- Algorithme de signature du certificat
- DN (Distinguished Name) du délivreur (autorité de certification)
- Validité (dates limite)
  - Pas avant (Début)
  - Pas après (Fin)
- DN du détenteur du certificat
- Informations sur la clé publique :
  - Algorithme de la clé publique
  - Clé publique proprement dite
- Identifiant unique du signataire (optionnel, X.509v2)
- Identifiant unique du détenteur du certificat (optionnel, X.509v2)
- Extensions (optionnel, à partir de X.509v3)
  - Liste des extensions
- Signature des informations ci-dessus par l'autorité de certification

© PSO - 2023

Description d'un sujet ou d'un CA

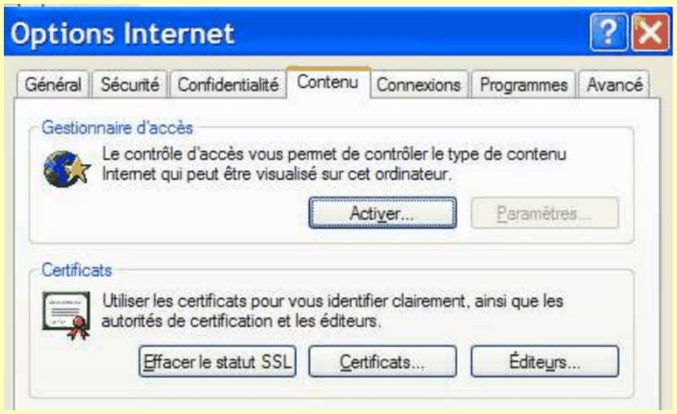
La description du sujet (possesseur de la clé publique) et du CA peuvent utiliser les abréviations suivantes :

- C (country) : Pays
- S (State) ou P (Province) : Etat ou Province
- L (Locality) : Ville
- O (Organization) : Société
- OU (Organization Unit) : Service
- CN (Common Name) : Le nom du sujet ou l'adresse DNS du serveur
- E (E-mail) : adresse e-mail

© PSO - 2023

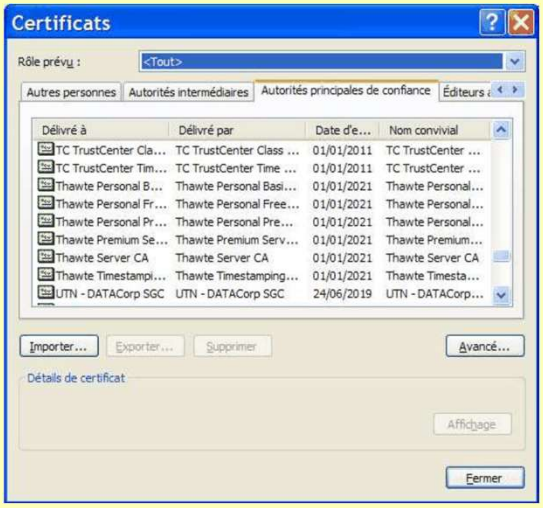
- Les certificats X509, version 3, sont utilisés dans diverses applications ou protocoles comme :
  - SSL/TLS.
  - IPSec.
  - authentification...
- Pour procéder à la signature d'un certificat, **l'organisme tiers effectue une condensation puis un cryptage des données avec une clé privée.**
- Bien entendu, la clé publique de l'organisme est à la disposition de tous. En fait, les préréglages des explorateurs comme Internet Explorer incluent une liste d'organismes certificateurs.

© PSO - 2023



© PSO - 2023

Pour résumer, si vous vous connectez sur un site SSL dont le certificat est signé par l'un des organismes déclaré sur votre explorateur, vous n'aurez pas d'alerte de sécurité car le site sera crédité d'un certain niveau de confiance.



© PSO - 2023

Si le certificat n'est pas signé par un organisme reconnu, vous aurez une alerte au moment de la connexion au serveur **https** comme ci-dessous :

© PSO - 2023

La hiérarchie des CA

- Un certificat d'un CA intermédiaire peut signer d'autres certificats. Mais il est lui-même signé par un CA hiérarchiquement supérieur, et ainsi de suite. Au sommet de cette pyramide , il ya les certificats CA ROOT qui sont auto-signés : le sujet et le signataire sont les mêmes.

© PSO - 2023

- Il est donc fortement conseillé de se faire signer un certificat par un organisme réputé "sérieux".
- La procédure à suivre est la suivante :

  On génère la paire de clés puis on s'adresse à l'organisme certificateur en lui envoyant une demande, la clé publique, les justificatifs demandés (inscription au registre du commerce, preuve de la possession du nom de domaine…), et le prix fixé (comptez 200$ par an au minimum).

© PSO - 2023

Infrastructure de clé publique

- L'infrastructure (de gestion) de clé publique plus connu sous le nom de **PKI** (Public Key Infrastructure) décrit les lois, stratégies, normes et logiciels qui régissent ou manipulent les certificats ainsi que les clés publiques et privées.
- Dans la pratique, il s'agit d'un système de certificats numériques, d'Autorités de certification et d'autres autorités d'enregistrement qui **vérifient et authentifient la validité de chacune des parties** impliquées dans une transaction électronique.

© PSO - 2023

Les composants d'une PKI 1/2

- **Les certificats** : Un certificats associe une clé publique et l'identité d'un utilisateur (son email) ou d'un serveur (son nom DNS) le tout signé par un CA.
- **Les CA** : Il créé les certificat en les signant. Il vérifie l'authenticité des données présentes dans une requête de certificats.
- 2 types de CA :
  - Les CA public : leur certificats vérifient l'identité des serveurs sur internet.
  - Les CA privé : CA interne d'une société.

© PSO - 2023

Les composants d'une PKI 2/2

- **Les CRL** (Certificat Revocation List)Si un pirate obtient la clé privé d'un serveur, il fut créer un nouveau certificat et révoquer l'ancien.
- Une CRL contient au niveau d'un CA, la liste des certificats révoqué qui n'ont pas encore expiré.

© PSO - 2023